MINI PROJECT • IoT CASE STUDY

IoT Security Challenges

A Case Study of Connected Devices and the Mirai Botnet

Submitted by	Omesh Gupta
Programme	B.Tech–M.Tech, Computer Science & Engineering (Cyber Security)
Institution	Uttar Pradesh State Institute of Forensic Science, Lucknow
Project type	Task 4 — Mini Project: IoT Case Study

Abstract

The Internet of Things (IoT) connects physical objects—such as cameras, routers, sensors, appliances and industrial controllers—to networks and digital services. This connectivity enables automation and remote monitoring, but it also expands the attack surface. Weak default credentials, insecure update mechanisms, exposed services, poor data protection and limited device support can allow attackers to compromise devices at scale. This case study examines these recurring security challenges through the widely reported Mirai botnet incident of 2016, which recruited vulnerable internet-connected devices and used them to launch disruptive distributed denial-of-service (DDoS) attacks. It explains the technical and organisational causes, considers the consequences, and proposes a layered mitigation plan for manufacturers, network operators and device owners. The central finding is that IoT security must be designed and maintained across the device lifecycle rather than treated as a one-time configuration task.

Keywords: Internet of Things, cybersecurity, botnet, Mirai, DDoS, device lifecycle, risk management

1. Introduction and Scope

The Internet of Things (IoT) describes networked physical devices that sense, process or exchange data and may be controlled remotely. Examples include smart-home cameras, connected locks, environmental sensors, wearable devices, medical equipment and industrial monitoring systems. Their value comes from continuous data collection and automated action. However, unlike traditional computers, many IoT devices have limited memory, processing power, user interfaces and long replacement cycles. Security controls may therefore be omitted, difficult to configure or neglected after deployment.

IoT security is not limited to preventing a device from being hacked. A compromised camera can become part of a botnet; a vulnerable sensor can expose private information; and an insecure industrial controller can affect availability or physical processes. The impact depends on the device's purpose, privileges, network placement and the sensitivity of the data it handles.

Objectives

- Identify common technical and lifecycle-related IoT security weaknesses.
- Use the Mirai botnet incident as a real-world case study of large-scale device compromise.
- Assess likely consequences for users, organisations and internet services.
- Recommend practical preventive, detective and corrective controls.
- Define measurable steps for improving IoT security governance.

Scope and method

This is a desk-based case study using publicly documented cybersecurity guidance and incident reporting. It focuses on general-purpose connected devices and botnet risk, not on testing any live device or network. Mirai is used as an illustrative incident because it demonstrated how insecure, internet-exposed IoT devices can be aggregated into a disruptive attack capability. The report does not attempt to reproduce malware or provide operational attack instructions.

IoT system overview

A typical IoT environment includes (1) a device with sensors/actuators and firmware, (2) a local network or gateway, (3) an internet connection, (4) a cloud platform or management service, and (5) a user or business application. Security failure at any layer can affect the entire system. For example, strong cloud authentication cannot fully compensate for an exposed device that accepts easily guessed credentials, while a secure device may still leak data if the application or cloud storage is misconfigured.

2. Major IoT Security Challenges

2.1 Weak authentication and default credentials

Devices may ship with shared factory credentials, weak passwords or limited support for multi-factor authentication. If owners do not change defaults, an attacker may gain access through credential guessing or previously disclosed credentials. Unique credentials per device, forced setup changes and rate limiting reduce this risk.

2.2 Insecure firmware and update processes

Firmware vulnerabilities can remain exploitable for years when vendors do not provide patches or users do not install them. Updates can themselves become a risk if packages are not authenticated, update channels are insecure, or devices cannot recover safely from a failed update. Secure boot, signed updates, a published support period and a reliable patch mechanism are important safeguards.

2.3 Exposed network services and poor configuration

Remote administration interfaces, debugging services and unnecessary ports may be reachable from the public internet. UPnP or permissive firewall rules can unintentionally expose devices. Secure deployment should disable unused services, restrict management access, segment devices from sensitive systems and avoid direct internet exposure unless there is a clear, protected requirement.

2.4 Privacy and data protection

IoT devices can collect video, audio, location, health information, occupancy patterns and industrial telemetry. Excessive collection, weak encryption, broad access permissions or long retention periods can create privacy risks. Organisations should minimise collected data, encrypt it in transit and at rest where appropriate, document retention, and provide clear notice and access controls.

2.5 Resource constraints and long lifecycles

Low-cost devices may lack sufficient resources for heavyweight security tools, and some remain installed long after vendor support ends. Devices may also be difficult to inventory or physically access. Security architecture should match controls to device capability, while procurement should require support commitments, vulnerability disclosure channels and an end-of-life plan.

2.6 Supply-chain and ecosystem complexity

An IoT product may rely on third-party chipsets, software libraries, mobile applications, cloud APIs and external service providers. A weakness in one component can affect many product lines. Software bills of materials (SBOMs), supplier assessments, secure development practices and coordinated vulnerability disclosure help organisations understand and manage this dependency risk.

2.7 Limited monitoring and accountability

Devices often produce little useful security telemetry, and responsibility may be split among manufacturers, installers, internet providers and owners. Without asset inventories, logs and a clear response process, compromise may go unnoticed. Monitoring should look for unexpected outbound traffic, repeated authentication failures, unusual device behaviour and communication with unapproved destinations.

3. Case Study: The Mirai Botnet

3.1 Background

In 2016, the Mirai botnet became a prominent example of how poorly secured IoT devices could be misused at internet scale. Public incident reports describe Mirai scanning for internet-connected devices and attempting to log in using a set of common or factory-default credentials. Devices that were successfully compromised could be directed by command infrastructure and used as part of a distributed denial-of-service (DDoS) network. The botnet's source code later became publicly available, contributing to the appearance of variants.

3.2 What happened and why it mattered

The incident demonstrated that devices designed for ordinary purposes—such as network cameras and digital video recorders—could be repurposed without their owners' knowledge. In October 2016, a major DDoS attack against DNS provider Dyn disrupted access to a number of well-known online services. Public reporting linked Mirai-infected IoT devices to the attack. The case highlighted that the security of an individual device can have consequences far beyond its owner: when many devices are compromised simultaneously, their combined traffic can affect shared internet infrastructure.

3.3 Attack chain at a high level

Stage	Description
1. Discovery	Automated scanning identifies internet-reachable devices.
2. Access attempt	Common or factory-default credentials are tried against exposed services.
3. Compromise	Vulnerable devices are infected and become remotely controllable.
4. Aggregation	Many compromised devices are coordinated as a botnet.
5. Disruption	The botnet generates large volumes of traffic against selected targets.

3.4 Root causes and lessons

- Weak device identity: shared or predictable credentials made large numbers of devices easier to compromise.
- Internet exposure: management services were reachable from outside the intended environment.
- Scale: individually small devices became powerful collectively when coordinated.
- Lifecycle gaps: users often lacked a clear way to patch, secure or retire devices.
- Shared responsibility: device makers, deployers, network operators and owners each controlled part of the risk.

The key lesson is that security weaknesses in inexpensive devices are not necessarily low-impact. Their aggregate effect can threaten availability for unrelated organisations and users. Strong defaults, restricted exposure, timely updates and ecosystem-level coordination are therefore essential.

4. Risk Assessment and Mitigation Plan

The following qualitative assessment prioritises common IoT risks. Ratings are illustrative and should be adjusted to the specific environment, threat model and business impact.

Risk	Likelihood	Impact	Priority	Key control
Default/weak credentials	High	High	Critical	Unique credentials; change at setup; rate limiting
Unpatched firmware	Medium–High	High	High	Signed updates; support policy; patch tracking
Exposed admin services	Medium–High	High	High	Firewall; VPN/secure gateway; disable unused services
Sensitive data leakage	Medium	High	High	Encryption; data minimisation; access control
Unknown/unsupported devices	Medium	Medium–High	Medium–High	Asset inventory; supplier and end-of-life review

4.1 Recommended controls by stakeholder

- Manufacturers: use unique device identities and secure-by-default settings; remove unnecessary services; encrypt sensitive communications; support signed firmware updates; publish a support lifetime and vulnerability-reporting route; test products before release.
- Device owners and organisations: change default passwords, apply updates, maintain an inventory, remove unsupported devices, disable unused features and place IoT devices on separate network segments.
- Network administrators: block unnecessary inbound connections, restrict outbound traffic where practical, monitor DNS and traffic patterns, and alert on unusual volumes or unexpected destinations.
- Procurement and governance teams: require evidence of secure development, update support, data-handling practices and incident notification in supplier contracts.
- Incident responders: prepare isolation procedures, preserve relevant logs, identify affected device models, coordinate with vendors and restore only after remediation.

4.2 Implementation roadmap

Timeline	Priority actions	Evidence of completion
0–30 days	Inventory devices; change default credentials; remove direct internet exposure where unnecessary.	Approved asset list; configuration review; exposed-service checks.
31–60 days	Patch supported devices; segment IoT networks; establish alerting and incident contacts.	Patch records; network rules; tested escalation contact list.
61–90 days	Review suppliers and end-of-life devices; formalise lifecycle policy and periodic review.	Supplier checklist; retirement plan; quarterly review schedule.

5. Evaluation, Conclusion and References

5.1 How to measure improvement

Security improvements should be tracked with practical indicators rather than relying only on policy documents. Suggested measures include:

- Percentage of IoT assets inventoried and assigned an owner.
- Percentage of supported devices running approved firmware versions.
- Number of devices exposed directly to the internet without an approved exception.
- Time from vendor security advisory to patch deployment or documented mitigation.
- Percentage of devices using unique credentials and encrypted management channels.
- Time required to detect, isolate and recover from a simulated IoT compromise.

A baseline should be recorded first, then targets set according to the organisation’s risk appetite and operational constraints. Metrics should be reviewed regularly and should not encourage unsafe patching or concealment of incidents.

5.2 Conclusion

IoT technologies create valuable capabilities in homes, cities, healthcare and industry, but their security weaknesses can extend beyond individual devices. The Mirai incident showed how default credentials, exposed services and insufficient lifecycle controls can allow large numbers of devices to be combined into a disruptive botnet. Effective protection requires a defence-in-depth approach: secure product design, strong authentication, signed updates, network segmentation, data minimisation, monitoring and a clear end-of-life process. No single control is sufficient. Manufacturers, buyers, operators and device owners must share responsibility, and security should be evaluated throughout procurement, deployment, operation and retirement. By applying these measures and tracking measurable outcomes, organisations can reduce the likelihood and impact of IoT compromise while retaining the benefits of connected technology.

References

[1] National Institute of Standards and Technology (NIST), Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risks, NISTIR 8228, 2019. https://doi.org/10.6028/NIST.IR.8228

[2] NIST, IoT Device Cybersecurity Capability Core Baseline, NISTIR 8259A, 2020. https://doi.org/10.6028/NIST.IR.8259A

[3] Cybersecurity and Infrastructure Security Agency (CISA), Understanding and Responding to Distributed Denial-of-Service Attacks and related DDoS guidance. https://www.cisa.gov/

[4] Krebs on Security, “Hacked Cameras, DVRs Powered Today’s Massive Internet Outage,” October 21, 2016. https://krebsonsecurity.com/2016/10/hacked-cameras-dvrs-powered-todays-massive-internet-outage/

[5] OWASP Foundation, OWASP Internet of Things Project and IoT security guidance. https://owasp.org/www-project-internet-of-things/

[6] European Union Agency for Cybersecurity (ENISA), Baseline Security Recommendations for IoT, 2017. https://www.enisa.europa.eu/publications/baseline-security-recommendations-for-iot

Note: The case study summarises public reporting and established security guidance. Risk ratings are illustrative, and no original penetration test or scan was performed for this report.